

Chapter 4:
APPLICATION AND OS SECURITY

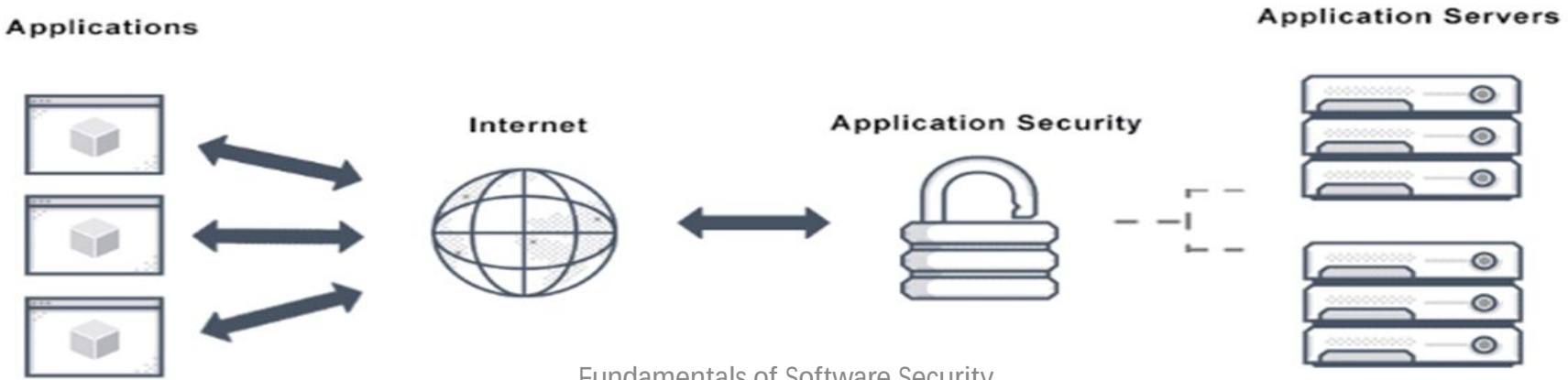
By:Tagel W.(M.Sc.)

Outlines

- **Application Code Attacks (Buffer Overflows), Session Hijacks**
- **Prevention: System Design, Robust coding, Isolation**
- **Users Management and Risk Management**
- **Enforcement of Security**
- **OS Access Control, Authentication**
- **Information Security: Policies and Procedures**
- **Legal Issues and Information Security: Computer Forensics**

Application Security

- **Application security:** is the process of protecting software applications from a wide range of threats, such as malware, buffer overflow attacks, SQL injection attacks, and cross-site scripting (XSS) attacks.
- It involves a combination of measures such as secure coding practices, input validation, encryption, and access control to prevent unauthorized access or modification of data.

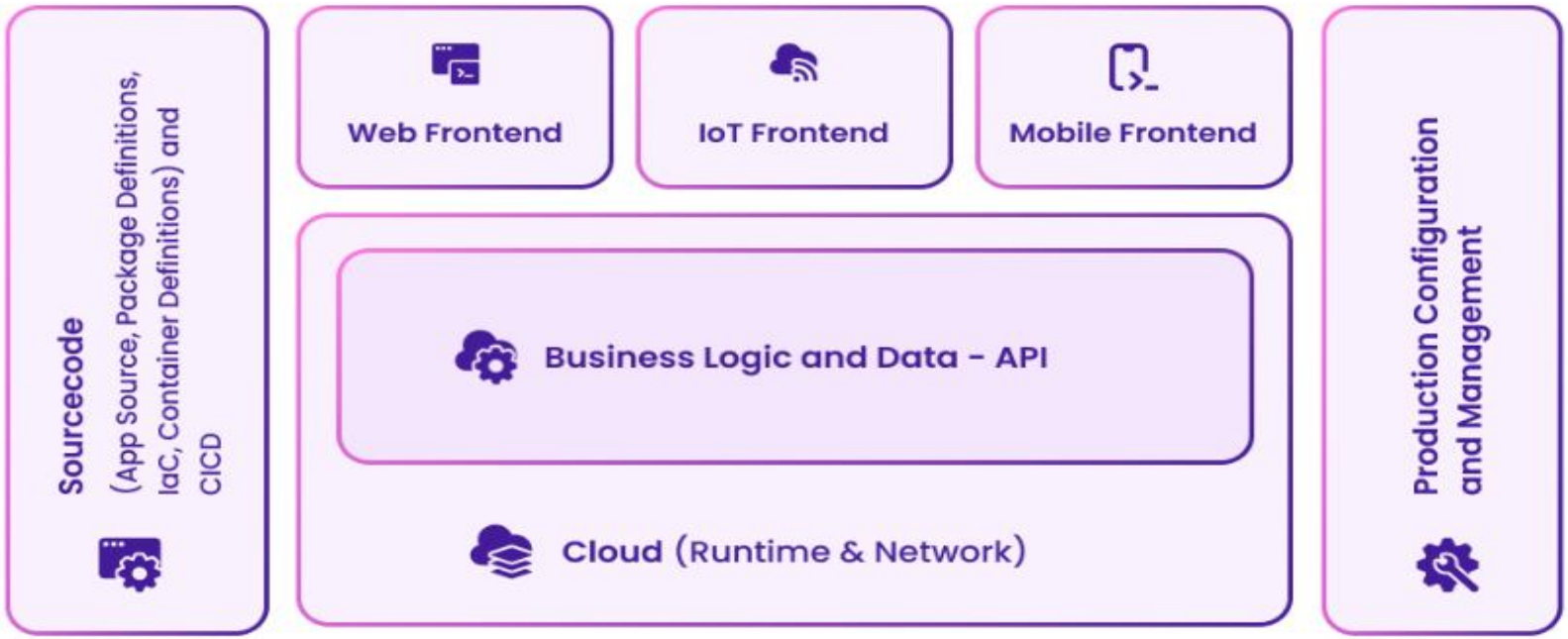


Application Security

- Applying application security throughout the software development lifecycle (SDLC) is an essential process to ensure that applications are secure and protected against potential threats.
- Introduce security standards and tools during design and application development phases. E.g. vulnerability scanning during early development.
- Implement security procedures and systems to protect applications in production environments. E.g. perform continuous security testing.
- Implement strong authentication for applications that contain sensitive data or mission critical.
- Use security systems such as firewalls, web application firewalls (WAF), and intrusion prevention systems (IPS).

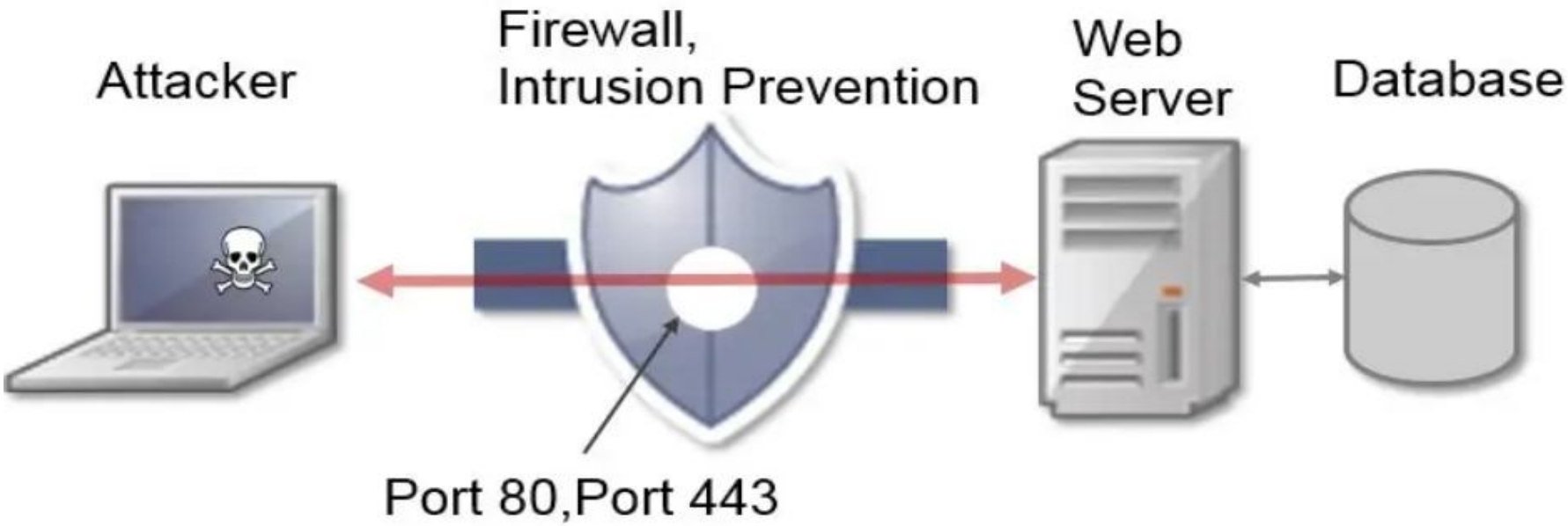
Application Security Architecture

- **Application Security Architecture:** are used to identify and assess security weaknesses due to architectural flaws in an application.
- a holistic approach to security, with multiple layers of protection and a focus on identifying and mitigating potential risks and vulnerabilities.



Application Security Attack

- is a type of cyber attack that targets software applications in order to exploit vulnerabilities and gain unauthorized access to data or systems.
- Security issues with web applications range from large-scale network disruption to focused database tampering.



- The following are some of Application Security Attacks:

Application Security Attacks…

1. Broken Access Control: type of security vulnerability that occurs when an application fails to properly enforce access control rules, allowing unauthorized users to access sensitive data or perform unauthorized actions.

- The most common issues:

a. Vertical privilege escalation: occurs when an attacker is able to gain access to higher-level privileges than they are authorized for, such as exploiting a vulnerability in an application's authentication mechanism.

b. Cryptographic Failures:- sensitive data exposure

- occur when data is not properly protected in transit and at rest.
- It can expose passwords, health records, credit card numbers, and personal data.

Application Security Attack…

2. Security Misconfiguration: is a type of security vulnerability that occurs when an application or system is configured in a way that leaves it vulnerable to attack.

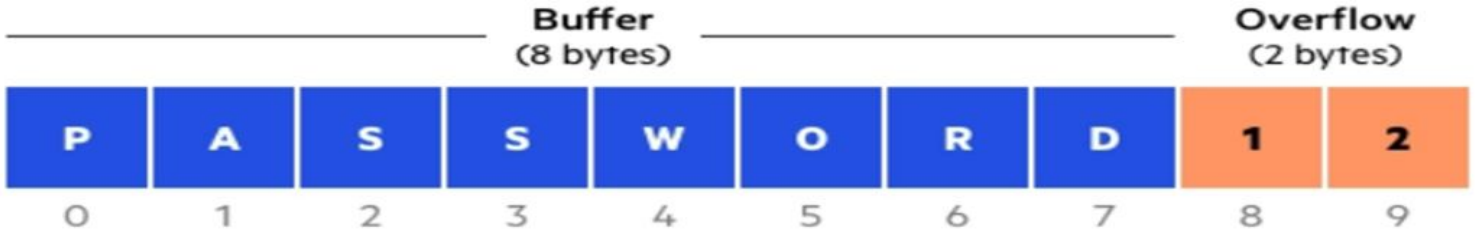
- Common Security Misconfigurations includes:
- Using default passwords or admin accounts
- Outdated software
- Unsecured ports and services:
- Failing to apply updates or patches, or misconfiguring security settings.

3. XML External Entities (XXE) Vulnerabilities: occur when an application processes XML input from an untrusted source without properly validating or sanitizing the input.

Application Security Attacks…

4. Buffer Overflow(Buffer Overrun): is a type of software vulnerability that can be exploited by attackers to execute arbitrary code or cause a denial of service (DoS) attack.

- It occurs when the volume of data exceeds the storage capacity of the memory buffer.
- This can cause the data to spill over into adjacent memory locations, potentially overwriting other critical data causing the program to behave unpredictably or crash.
- E.g. C, C++



Application Security Attacks…

- Solutions for Buffer Overflow
  a. Address space randomization (ASR): randomly moves around the address space locations of data regions.
  b. Data execution prevention:-flags certain areas of memory as non-executable or executable, which stops an attack from running code in a non-executable region.
  c. Input validation

5. Fuzzing Attack: is a type of automated software testing that involves sending random or malformed inputs to a target system to identify vulnerabilities or defects.

- an attacker uses a fuzzing tool to generate a large number of random or mutated inputs and sends them to the target system in an attempt to find vulnerabilities.

Application Security Attacks…

- Fuzzing attack ….

- generation-based fuzzing, to generate inputs that are designed to trigger specific types of vulnerabilities, such as buffer overflow or SQL injection.

- Protection mechanism
  - implement secure coding practices, such as input validation and error handling, to handle unexpected inputs.
  - use specialized tools, such as fuzzing frameworks and security scanners, to test the security and robustness of the applications and systems before deployed in production environments.
  - network administrators can also use intrusion detection and prevention systems (IDPS) to detect and block fuzzing attacks in real-time.

Application Security Attacks…

6. Cross-Site Scripting Attacks(XSS): occur when an attacker is able to inject malicious code, in the form of a script, into a web page that is then executed by the user's browser.

- XSS attacks; are dangerous and difficult to detect. They can allow attackers to masquerade as authorized users, harvest personal data, or deface a website.
- The three main types of cross-site scripting (XSS) attacks are:

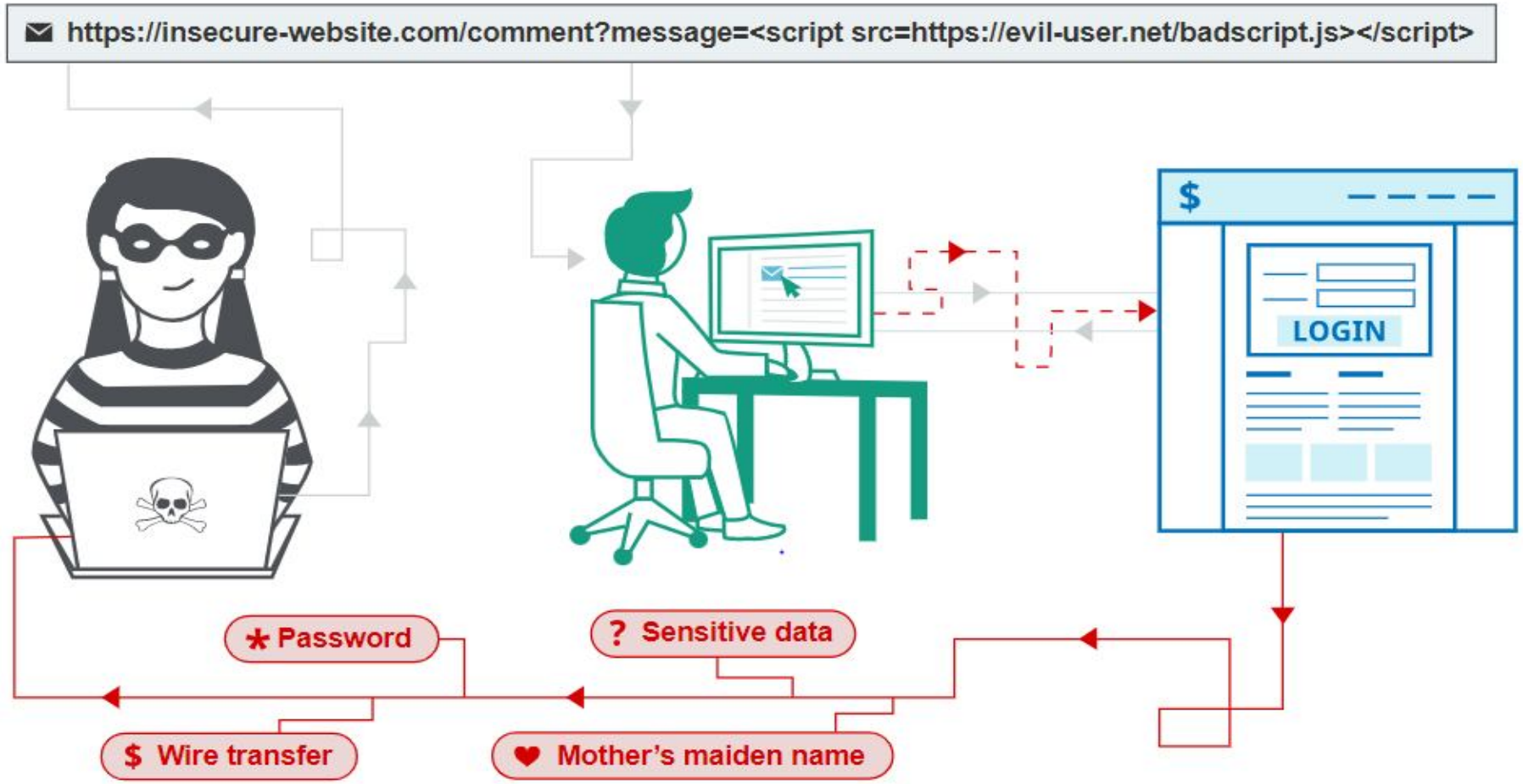
  a. Stored(Persistent) XSS attack: the attacker is able to inject malicious code directly into the web application's database,

  b. Reflected(Non-Persistent) XSS attack: the attacker is able to inject malicious code into a web page that is immediately returned to the user's browser as part of a response from the server.

  c. DOM-based XSS attack: the attacker manipulates the Document Object Model (DOM) of the user's browser. This causes the client-side code to be executed in an unintended way.

Application Security Attacks…

- Cross-site scripting attacks(XSS)…



- Protection

- software developers must validate user input and encode output.

Application Security Attacks…

7. SQL Injection Attacks: are a type of cyber attack that target web applications that use SQL databases.

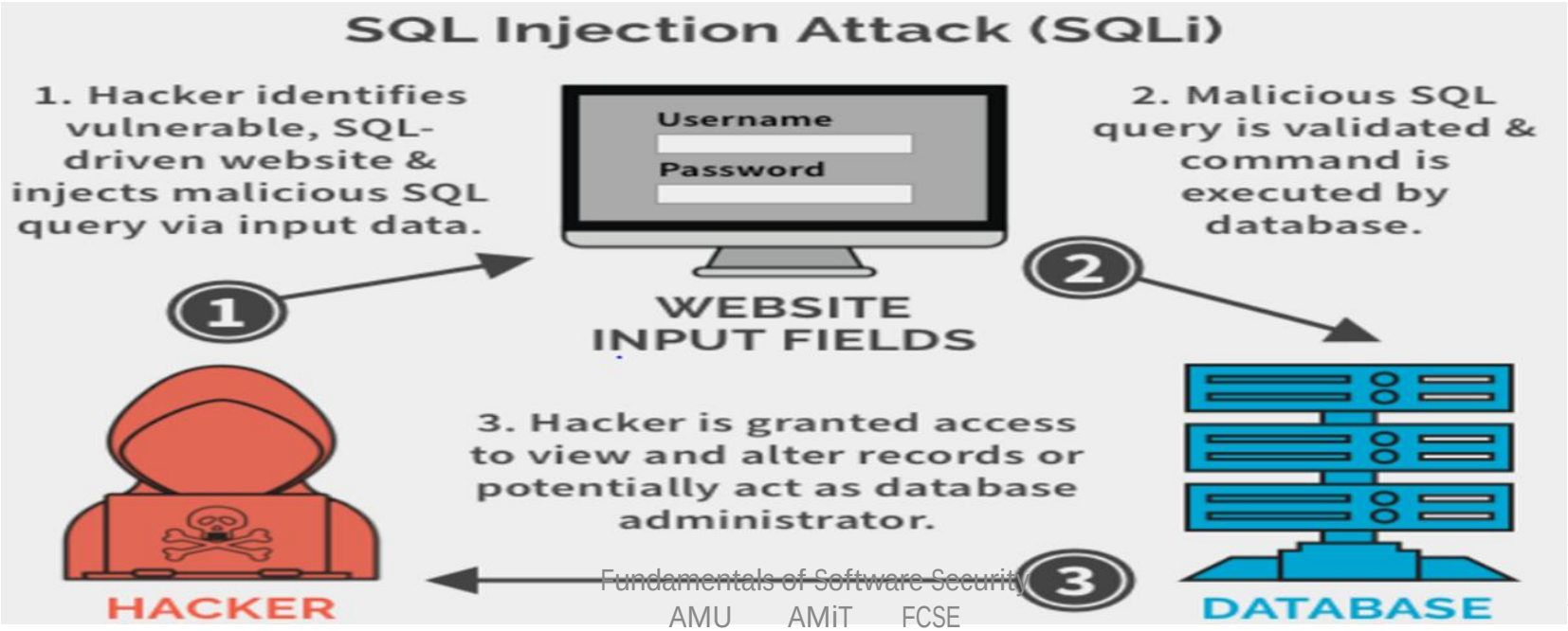
- The attacks inserting malicious SQL code into an application's input fields, which can be executed by the underlying database.
- The goal SQL injection attack is to manipulate the database to perform unauthorized actions, such as retrieving sensitive data or modifying database records.
- It can occur when an application does not properly validate user input or sanitize user input before using it in SQL queries.

Application Security Attacks…

- SQL Injection Attacks…

- Retrieve any number of items, including sensitive company data, user lists or private customer details.

```
SELECT ItemName, ItemDescription
        FROM Item
WHERE ItemNumber = ItemNumber
```



Application Security Attacks…

8. Hijacking: is a type of network attack in which the attacker takes over control and communication between the victim system and the network.

- Any kind of information theft including password, email information, bank account information, etc.



- Prevention
- Encrypting all data transmitted on a web page.
- Using HTTPS certification on websites.
- Keeping your browsers updated and patched.

Types of Application Security

- Authentication, authorization, encryption, logging, and application security testing are all examples of application security features.
- **Authentication and Access Control:** involves implementing strong authentication mechanisms such as passwords, biometric authentication, and multi-factor authentication to ensure that only authorized users can access the application.
- The developers include protocols in an application to ensure that only authorized users have access to it. e.g. SSH, LDAP etc
- **Regular Security Assessments:** conducting regular security assessments and audits to identify and address security weaknesses in the application and its environment.

Types of Application Security…

- **Authorization:-** a user may be authorized to access and use the application after being authenticated.
- Comparing the user's identification to a list of authorized users, the system may verify that the user has permission to access the application.
- **Encryption:-** a security measures can safeguard sensitive data from being seen or utilized by a cybercriminal after a user has been verified and using the application.
- Traffic containing sensitive data that flows between end-user and cloud in cloud-based applications can be encrypted to keep the data safe.
- **Logging:-** it can assist in determining who gained access to the data and how they did
- Application log files keep track of which parts of the application have been accessed and by whom.

Tools for Application Security

- A complete application security approach used for detection, remediation and resolution of a variety of application vulnerabilities and security challenges.
- Finding the right application security technologies for organization is crucial to the effectiveness of any security measures for security team implements.
- **Application Security Testing:-** is the process of evaluating an application's security posture to identify vulnerabilities and weaknesses that could be exploited by attackers
- Application security Testing can be divided into numerous categories
  1. Static Application Security Testing (SAST)
  2. Dynamic Application Security Testing (DAST)
  3. Interactive Application Security Testing (IAST)
  4. Run-time Application Security Protection (RASP)

Categories of Application Security Testing

1. Static Application Security Testing (SAST)

- It is white-box testing with access to source code, at rest, identifies weaknesses that may lead to a vulnerability and generates a report
- analyzing the source code of an application for security vulnerabilities
- This testing can detect issues of buffer overflows, SQL injection etc., which performed during the development phase of an application.
- E.g. syntax errors, input validation issues
- The ability to compare static analysis scan results with real-time solutions speeds up the detection of security problems, decreasing MTTR and enabling collaborative troubleshooting.

Application security Testing…

2. Dynamic Application Security Testing (DAST)

- It is a more reactive approach, simulating security breaches on a live web application to deliver precise information about exploitable flaws
- It is useful for detecting runtime or environment-related errors because it evaluates applications in production.
- helps identify issues such as query strings, use of scripts, requests and responses, memory leakage, authentication, cookie and session handling, execution of third-party components, and data injection.
- It does not require access to the application's source code.

Application security Testing…

3. Interactive Application Security Testing (IAST)

- It combines parts of SAST and DAST
- It scans the source code for vulnerabilities while running the application and simulating the ways a user would commonly interact with it
- helps make remediation easier by providing information about root cause of vulnerabilities and analyze data flow, source code, configuration, and third-party libraries.
- It has access to all the application's code and components, allowing to produce more accurate results and provide more in-depth access than previous versions.

Application security Testing…

4. Run-time Application Security Protection (RASP)

- Tools could be considered a combination of testing and shielding.
- It provides continuous security checks and automatic responses to possible breaches, e.g. send alerts , terminate session or terminate the app itself if compromised
- Tools are continuously monitoring behavior of the app, which is useful particularly in mobile environments when apps can be rewritten, run on a rooted phone or have privilege abuse to turn them into doing wicked things.

Application Security Approaches

1. Design Review: -architecture and design of the application can be examined for security flaws before code is created.

The construction of a threat model is a popular strategy used at this phase.

2. White-box Security Review or Code Review

- The security engineer inspecting source code and looking for security issues
- Vulnerabilities unique to the application can be discovered through understanding the application.

Application Security Approaches…

3. Black-box Security Audit:- accomplished only through the use of an application to test for security flaws, no source code is necessary.

4. Automated Tooling:-security tools can be automated by including in the development or testing process.

- Automated DAST/SAST tools that incorporated into code editors or continuous integration (CI)/continuous deployment(CD)systems

5. Coordinated Vulnerability Platform:-Many websites and software providers offer hacker-powered application security solutions through which individuals can be recognized and compensated for reporting defects.

Operating System Security

- **Operating System Security:** the process of protecting the underlying software and hardware that runs a computer or other digital device.
- It is responsible for managing system resources, controlling access to sensitive data, and providing a platform for running applications.
- **Common OS Security Threats includes:**
  - **Malware:** is malicious software that is designed to compromise the security of a system. E.g. viruses, worms, Trojans, and ransomware.
  - It can be used to steal sensitive data, hijack system resources, or cause damage to the OS or other software installed on the system.
  - **A Denial of Service (DoS) attack:** is intended to clog a system with fake requests so it becomes overloaded, and eventually stops serving legitimate requests.

OS Security Threats…

- **Trojan Horse:** it seem to be attractive and harmless cover programs but are really harmful hidden programs that can be used as the virus carrier
- **Worms:** a type of malware that replicates itself and infects other computers while remaining active on affected systems.
- **Port scanning:** is a mechanism or means by which a hacker can detects system vulnerabilities to make an attack on the system.
- **Network intrusion:** occurs when an individual gains access to a system for improper use
- **Buffer Overflow:** temporary data stores are overflowing with data

Operating System Security

- Authentication: is the responsibility of the Operating System to create a protection system which ensures that a user who is running a particular program is authentic. E.g. user name and password, Biometric signatures etc.
- One Time passwords :- a unique password is required every time user tries to login into the system
- Operating System Policy and Procedures are :
- Installing and updating anti-virus software
- Ensure the systems are patched or updated regularly
- Implementing user management policies to protect user accounts and privileges.
- Installing a firewall and ensuring that properly set to monitor all incoming and outgoing traffic.

Operating System Security

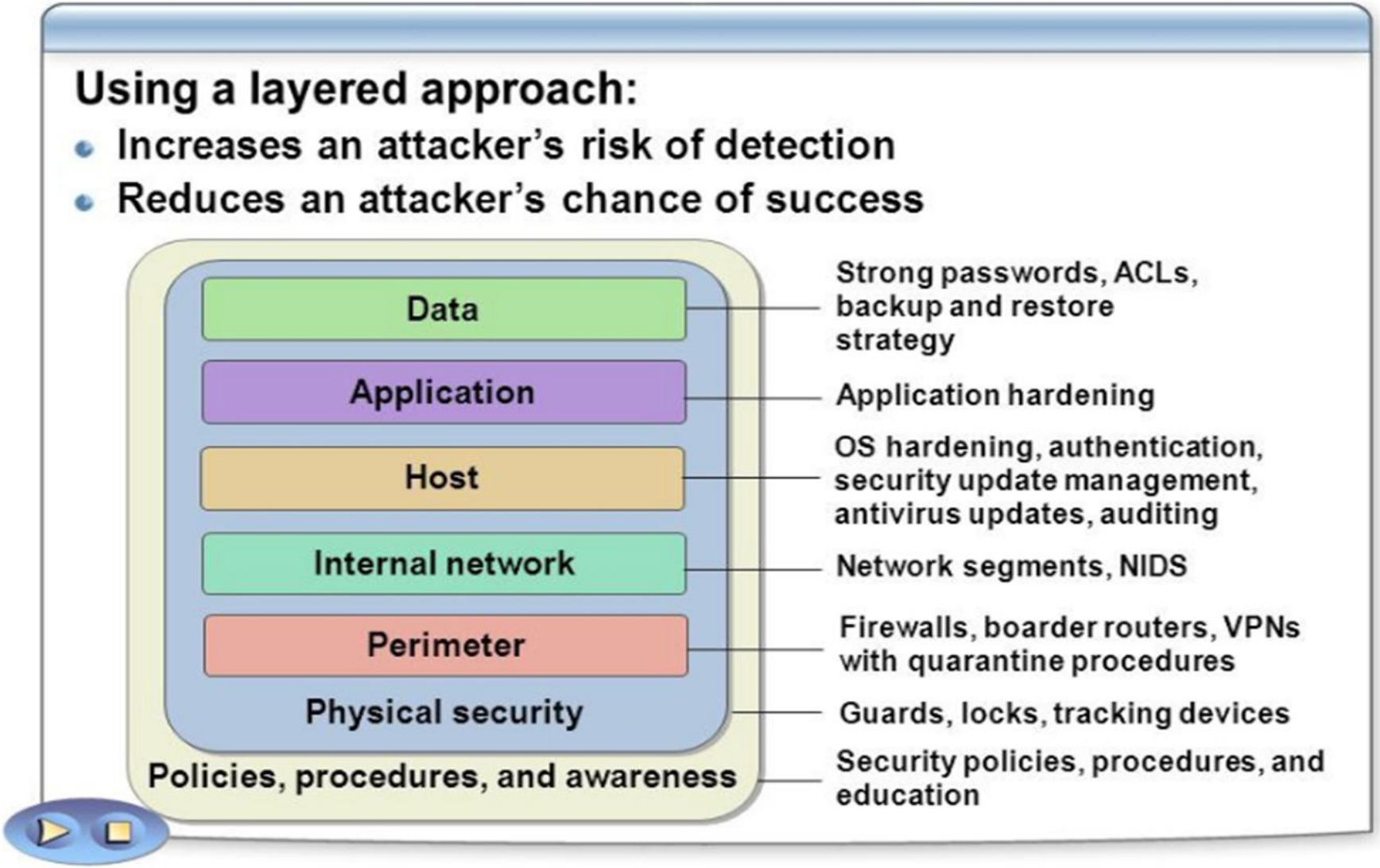
- Access control:- specifies who can have access to a system resource and what type of access each entity has.
- User management:- enables users to access and control digital assets, such as applications, devices, networks
- Information security policy:- is a set of rules, policies and procedures designed to ensure all end users and networks within an organization meet minimum IT security and data protection security requirements.

e.g. Password policy , data backup policy, security system managment policy

- Computer Forensics (Reading Assignment!)

Other Security Aspects

Comprehensive Security



- **Mobile Security:** the protection of mobile devices, such as smartphones and tablets, from unauthorized access, theft, malware, and other security threats.

- Mobile devices can be attacked by potentially malicious apps, network-level attacks, and exploitation of vulnerabilities within the devices and mobile OS.

Protection

- Keep your software updated
- Install a firewall.
- Download apps from official app stores.
- Always read the end-user agreement.

- **Web Security:** the practice of protecting websites and web applications from various types of cybersecurity threats, such as hacking, data breaches, and malware.
- websites and web applications often handle sensitive information, such as user passwords and financial data, and a security breach can have serious consequences for both users and businesses.
- protection: browser policies, session mgmt, user authentication
  - ✓ HTTPS
  - ✓ Web application firewall

- **Network Security:** the practice of protecting computer networks from various types of cybersecurity threats, such as unauthorized access, data breaches, and malware.
- Network security is important because computer networks often handle sensitive information, such as personal data, financial information, and intellectual property, and a security breach can have serious consequences for both individuals and organizations.
- protection
- Use access control
- VPN
- Firewall

Risk Management

- It is the process of identifying, assessing, and controlling risks that may impact an organization's operations, projects, or assets.
- It involves developing strategies and techniques to mitigate risks and minimize their potential impact on the organization.
- It is an essential component of business planning and decision-making, and it helps organizations to protect their assets, reduce losses, and improve their overall resilience.

◆ Risk Management Process involves the following steps:

1. Risk identification: This identifying potential risks that may impact the organization, such as financial risks, operational risks, or reputational risks.

Risk management…

2. Risk assessment: assessing the likelihood and potential impact of each identified risk, and prioritizing them based on their level of risk.

3. Risk mitigation: developing strategies and techniques to mitigate the potential impact of identified risks, such as implementing control measures, transferring risk to an insurance provider, or avoiding the risk altogether.

4. Risk monitoring and review: monitoring the effectiveness of the risk management strategies and reviewing the risk management plan on a regular basis to ensure that it remains relevant and effective.

Risk Treatment Options

- Four main risk management strategies, or risk treatment options:

1. Risk Avoidance: avoiding the activity or situation that poses the risk, either by not engaging in the activity or by changing the approach to eliminate the risk altogether.
2. Risk Reduction: taking steps to reduce the likelihood or impact of the risk.

✓ by implementing controls or safeguards, such as security measures to minimize the chances of the risk occurring or lessen its impact.

3. Risk Transfer: transferring the risk to another party, such as an insurance company or a third-party vendor

4. Risk Acceptance: accepting the risks and developing a plan to manage them if they occur. the cost of managing the risk is greater than the potential impact of the risk or when the risk cannot be avoided, reduced.

Risk Management Frameworks

- are a set of processes, policies, and procedures that are used to identify, assess, and manage risks in an organization.
- The goal of a risk management framework is to minimize the impact of potential risks on an organization's operations, assets, and reputation.
- It includes risk identification, risk measurement and assessment, risk mitigation, risk reporting and monitoring, and risk governance.

Security System Assessment and Evaluation

- **Security System Assessment:** is the process of evaluating the security of a system or application to identify vulnerabilities and weaknesses that could be exploited by attackers.
- The assessment typically involves a combination of manual and automated testing techniques, and may be performed by internal or external security experts.
- **Security System Evaluation:** is the process of determining whether a system or application meets a set of predefined security requirements or standards.

Security System Assessment and Evaluation

- The choice of assessment type depends on the goals and needs of the organization, as well as the specific risks and threats faced by the system or application.

- Types of Security System Assessment are:

  - **Vulnerability Assessment:** is the process of identifying potential vulnerabilities in a system or application, and assessing the potential risks associated with those vulnerabilities.

  - The goal of a vulnerability assessment is to identify potential weaknesses that could be exploited by attackers and to provide recommendations for mitigating those risks.

Security System Assessment

- **Penetrate Testing:** this type of assessment involves attempting to exploit vulnerabilities in the system to gain unauthorized access or to perform other malicious activities.
- The goal is to simulate a real-world attack and to identify areas where the security controls are insufficient.
- **Security Audit or Review:** a comprehensive assessment of an organization's security posture, policies, procedures, and controls.
- The goal of a security audit is to identify potential security risks and to provide recommendations for improving the overall security posture of the organization.

Security System assessment

- **Static Code Analysis:** This type of assessment involves reviewing the source code of the system or application to identify potential security vulnerabilities, such as buffer overflows, SQL injection, or cross-site scripting (XSS) attacks.
- The goal is to identify coding errors and to recommend remediation actions..
- Abuse Case Development (Reading Assignment!)

End of Chapter-4 and the Course!

Qn. if Any???

